

CISSP Printable Practice Exam 24 - Domain 8 - Software Development Security

Practice Exam 03 - Domain 8

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-136)

Scenario: A digital publishing team uses short Agile iterations. Security defects recur because user stories describe business behavior but do not state security conditions, and completed stories are accepted after functional testing alone.

Which change would BEST integrate security into the team's normal delivery process?

- A. Create a separate security backlog that is reviewed only before major releases.
- B. Add risk-based security acceptance criteria to applicable stories and include their verification in the Definition of Done.
- C. Ask the security team to rewrite every user story after developers complete the iteration.
- D. Permit product owners to accept stories with unresolved security criteria whenever functional objectives are met.

Question 2 (CISSP3-137)

Scenario: A property management company has completed a pilot of a new secure code-review process. Metrics show fewer escaped defects, but reviewers report that the approval workflow caused unnecessary delays for low-risk changes.

What should the process improvement lead do NEXT?

- A. Expand the pilot unchanged because the defect metric improved.
- B. Discard the process because one part of the workflow created delays.
- C. Begin an unrelated tooling initiative before documenting the pilot results.
- D. Analyze the outcomes and lessons, refine the risk-based workflow, and feed the findings into the next improvement cycle.

Question 3 (CISSP3-138)

Scenario: A hospital application team must upgrade a shared web framework to correct a security flaw. The framework also handles session management and request routing, and the application has extensive custom authorization logic.

What is the BEST testing approach before production deployment?

- A. Perform risk-based regression and security testing focused on affected framework behavior and dependent controls, while retaining a tested rollback plan.
- B. Test only the original framework flaw because vendor maintenance releases do not affect application behavior outside the documented fix.
- C. Repeat only end-user functional tests because successful navigation demonstrates that authorization remains effective.
- D. Deploy the update directly to production and use incident monitoring as the primary validation method.

Question 4 (CISSP3-139)

Scenario: At a small investment advisory firm, senior developers can write a change, approve their own review request, and deploy it to production. Management wants stronger control without requiring a large new release department.

Which control would MOST appropriately address the risk?

- A. Allow self-approval for developers who have worked at the firm for more than one

year.

- B. Rely on quarterly log review to identify improper deployments after they occur.
- C. Require independent approval for protected changes and restrict production deployment authority through the release workflow.
- D. Give all developers production access so responsibility for deployments is shared across the team.

Question 5 (CISSP3-140)

Scenario: A subscription service releases frequently, but development planning relies almost entirely on feature requests. Operations has identified recurring application attack patterns and repeated control failures that are corrected individually but rarely influence future design work.

Which TWO practices would BEST create an effective feedback loop into the SDLC? Select 2 of the 5 options below.

- A. Translate recurring production findings and attack patterns into prioritized backlog items, design guidance, and security requirements.
- B. Keep operational findings outside the development process so feature estimates remain stable.
- C. Measure development performance only by deployment frequency, regardless of recurring security failures.
- D. Close each incident record after service restoration without analyzing common software causes.
- E. Review trends across incidents, vulnerabilities, and control telemetry with development and product stakeholders at defined intervals.

Question 6 (CISSP3-141)

Scenario: A legal document portal builds file-system paths by appending a client-supplied filename to a document directory. A tester uses encoded parent-directory sequences to retrieve a configuration file outside the intended location.

Which remediation BEST addresses the underlying weakness?

- A. Reject only requests containing the literal sequence ../ before decoding the filename.
- B. Hide the document directory name and return a generic error for failed downloads.
- C. Encrypt configuration files while continuing to construct paths from client-supplied filenames.
- D. Map opaque identifiers to approved files server-side, canonicalize the resolved path, and verify it remains within the authorized directory.

Question 7 (CISSP3-142)

Scenario: A workflow application accepts serialized objects from partner systems and reconstructs application classes automatically. Security testing shows that crafted input can invoke unexpected class behavior during deserialization.

What is the BEST design-level correction?

- A. Base64-encode serialized objects so class names are not visible during transmission.
- B. Use a simple data format with an explicit schema, validate permitted fields and types, and avoid automatic instantiation of arbitrary classes.
- C. Retain native object deserialization but log the class name after each object has been created.
- D. Compress serialized input before processing to reduce the opportunity for

modification.

Question 8 (CISSP3-143)

Scenario: An image-processing service multiplies an uploaded image's width, height, and bytes per pixel to calculate a memory allocation. Very large values can wrap the calculation to a smaller number before the service copies image data into the buffer.

Which coding practice MOST directly prevents this condition?

- A. Perform the calculation first and compare the resulting buffer size with available memory.
- B. Increase the process memory limit so wrapped calculations are less likely to cause a failure.
- C. Validate dimensions against safe limits and use checked arithmetic that detects overflow before allocation and copying.
- D. Record failed image operations in a log and block the source address after repeated errors.

Question 9 (CISSP3-144)

Scenario: A video streaming company provisions application environments from infrastructure-as-code templates. Several recent changes enabled privileged workloads and overly broad storage permissions, even though the application source code passed review.

Which improvement would BEST prevent similar configuration defects from reaching production?

- A. Place templates under review and version control, evaluate them with policy-as-code checks in the pipeline, and block violations unless a governed exception is approved.
- B. Review cloud billing reports after deployment to identify environments likely to contain privileged workloads.
- C. Scan only the application source because infrastructure templates do not execute business logic.
- D. Permit deployment engineers to correct template settings manually in production without updating the source template.

Question 10 (CISSP3-145)

Scenario: A consulting firm's build system searches both an internal package store and a public registry. A public package with the same name as an internal component and a higher version number is selected automatically during a build.

Which control strategy would MOST effectively reduce this supply-chain risk?

- A. Allow the build to select the highest available version and investigate only when compilation fails.
- B. Rename internal packages periodically so public publishers cannot predict their future names.
- C. Block public packages only when their descriptions contain the firm's name.
- D. Route dependencies through a controlled repository, reserve internal namespaces, and pin approved package sources and versions.

Question 11 (CISSP3-146)

Scenario: A nonprofit organization is evaluating a hosted donor-management application. The supplier will not provide source code but permits testing of a dedicated preproduction tenant and can provide independent security assessment evidence.

What is the BEST assurance approach before acquisition?

- A. Treat the absence of source access as proof that meaningful security assessment is

impossible.

- B. Perform authorized risk-based dynamic testing of the tenant and evaluate current independent evidence, architecture information, and remediation practices.
- C. Run static analysis against the public login page and consider the resulting client-side findings a complete assessment.
- D. Rely on contract pricing and service availability targets as substitutes for application security evidence.

Question 12 (CISSP3-147)

Scenario: A ticketing platform exposes an API to approved partners. Authenticated clients can submit deeply nested payloads and issue high-cost search requests fast enough to exhaust application worker capacity.

Which TWO controls would MOST directly reduce these application-layer risks? Select 2 of the 5 options below.

- A. Increase worker capacity whenever request latency exceeds the target.
- B. Validate requests against a strict schema with limits on size, depth, fields, and query complexity.
- C. Use longer partner identifiers while retaining unrestricted request volume and payload structure.
- D. Encrypt API traffic with a stronger transport cipher while leaving resource consumption unconstrained.
- E. Enforce quotas and risk-appropriate rate or cost limits per authenticated client and operation.

Question 13 (CISSP3-148)

Scenario: An educational software team wants to adopt an open-source authentication component. The code appears functional, but releases are infrequent, unresolved security reports are increasing, and only one maintainer remains active.

What should the application security lead recommend?

- A. Approve the component because source availability ensures the community will correct future vulnerabilities.
- B. Reject all open-source software because maintenance risk exists only when code is publicly available.
- C. Assess maintainership, vulnerability response, dependency health, internal support capability, and replacement options before making a risk-based adoption decision.
- D. Adopt the component and postpone lifecycle analysis until the first security defect affects production.

Question 14 (CISSP3-149)

Scenario: A food delivery company cannot perform the same depth of manual security testing on every weekly release. One release changes only internal report formatting, while another modifies payment workflows and introduces a new external service integration.

How should the security testing effort be allocated?

- A. Use risk-based testing that gives greater depth to the payment and integration changes while maintaining defined baseline checks for all releases.
- B. Apply identical manual testing hours to both releases so the process treats every code change uniformly.
- C. Test only the larger code change because line count is the most reliable indicator of security impact.
- D. Skip testing of previously assessed components even when new integrations alter

their trust relationships.

Question 15 (CISSP3-150)

Scenario: A construction company receives an urgent update notice for commercial project-management software. The message links to an unfamiliar download host, although the update version appears consistent with the supplier's naming convention.

What should the software owner do FIRST?

- A. Install the update on one production workstation because the version name matches the existing product.
- B. Upload the package to a public analysis service before confirming whether the supplier released it.
- C. Forward the link to additional administrators and compare whether they receive the same file.
- D. Obtain the update through a trusted supplier channel and verify its digital signature or published integrity information before testing and deployment.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-136) - Correct: B

Security acceptance criteria attached to relevant stories make expected controls testable, while the Definition of Done prevents work from being considered complete before those criteria are verified. A separate late backlog delays risk treatment. Rewriting completed stories creates rework, and accepting unresolved criteria based only on functionality allows known security gaps to accumulate.

Question 2 (CISSP3-137) - Correct: D

The Learning phase uses measured results and practical lessons to improve future cycles and institutionalize what worked. Expanding the process unchanged ignores the delay evidence, while abandoning it ignores the demonstrated reduction in escaped defects. Starting another initiative before capturing lessons wastes the pilot's evidence and weakens continuous improvement.

Question 3 (CISSP3-138) - Correct: A

The shared framework affects sessions, routing, and custom authorization dependencies, so testing should cover the corrected flaw and the security-sensitive behavior most likely to regress. Testing only the published defect assumes away integration effects. Functional navigation does not fully validate authorization, and production monitoring is not a substitute for predeployment assurance and rollback readiness.

Question 4 (CISSP3-139) - Correct: C

Independent approval and controlled deployment permissions introduce separation of duties at the critical approval and release points without requiring a large organization. Tenure does not remove conflict of interest. Quarterly review is detective and delayed, while broader production access increases rather than reduces the opportunity for unauthorized change.

Question 5 (CISSP3-140) - Correct: A, E

Operational evidence improves software security when recurring patterns become prioritized development work and when cross-functional trend reviews influence requirements and design. Isolating findings prevents learning. Deployment frequency alone can conceal recurring weaknesses, and closing incidents without analyzing common causes treats symptoms without improving the lifecycle.

Question 6 (CISSP3-141) - Correct: D

Server-side identifier mapping plus canonicalization and boundary validation prevents alternate encodings and path normalization tricks from escaping the authorized directory. A literal block rule can be bypassed. Hiding names does not enforce access, and encryption may protect some file contents but leaves arbitrary file retrieval possible.

Question 7 (CISSP3-142) - Correct: B

Schema-constrained data parsing treats input as data and prevents untrusted content from selecting or instantiating arbitrary application classes. Encoding and compression change representation but not dangerous behavior. Logging after object creation may aid detection, yet execution may already have occurred and the unsafe design remains.

Question 8 (CISSP3-143) - Correct: C

Range validation and checked arithmetic detect an unsafe calculation before a truncated allocation can lead to an out-of-bounds copy. Examining only the wrapped result misses the overflow. Additional memory does not correct arithmetic behavior, and logging with source blocking is a detective response that does not remove the vulnerable code path.

Question 9 (CISSP3-144) - Correct: A

Versioned review and automated policy checks treat infrastructure configuration as part of the software delivery system and prevent prohibited settings before deployment. Billing reports do not validate security configuration. Source-only scanning misses infrastructure risk, and manual production corrections create drift while leaving the defective template unchanged.

Question 10 (CISSP3-145) - Correct: D

A controlled repository with namespace protection and explicit source and version rules prevents a public package from silently taking precedence over an internal dependency. Highest-version selection creates the weakness. Periodic renaming is fragile, and description-based blocking does not reliably establish package identity or provenance.

Question 11 (CISSP3-146) - Correct: B

When source is unavailable, authorized dynamic testing combined with credible independent evidence and supplier process information provides layered assurance about exposed behavior and governance. Lack of source limits some techniques but does not prevent assessment. Client-side static analysis is incomplete, while pricing and availability targets do not demonstrate application security effectiveness.

Question 12 (CISSP3-147) - Correct: B, E

Strict schema and complexity limits reject malformed or excessively expensive payload structures, while client- and operation-aware quotas constrain repeated resource consumption. Additional capacity may delay exhaustion without controlling abusive work. Identifier length is unrelated, and transport encryption protects confidentiality and integrity in transit rather than application resource usage.

Question 13 (CISSP3-148) - Correct: C

Open-source adoption should consider project health, response history, dependencies, the organization's ability to maintain or support the code, and an exit path. Source availability does not guarantee timely remediation. Rejecting all open source ignores risk differences among projects, while delaying analysis creates avoidable dependency and replacement risk.

Question 14 (CISSP3-149) - Correct: A

Risk-based allocation concentrates scarce manual effort where critical data, external exposure, and changed trust boundaries create greater potential impact, while baseline controls preserve minimum assurance elsewhere. Equal hours ignore material differences. Code size is a weak proxy for risk, and prior assessment does not cover new interactions that change a component's exposure.

Question 15 (CISSP3-150) - Correct: D

Trusted distribution and cryptographic verification establish provenance and integrity before the package enters the test or production process. A familiar version name is not authentication. Sending an unverified proprietary package to a public service may create exposure, and agreement among recipients does not prove that the download is genuine.